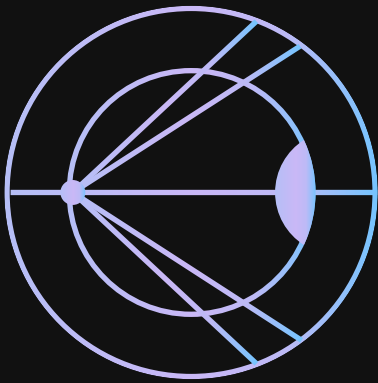




FINAL REPORT

Audit Contest

for **OxMarkets**

PREPARED BY

HackenProof

AUDIT DURATION

04.06-08.07.2026

REPORT CREATED

31.07.2026

AUDIT TYPE

Solidity

TABLE OF CONTENTS

Introduction	3
Audit summary	4
Findings list	4-7
About project	8

INTRODUCTION

HackenProof Audit is your solution to maximize cybersecurity through the involvement of the industry's most skilled and experienced community security researchers.

Name	Cartha Vault
Website	https://www.0xmarkets.io/
Type	Audit Contest
Date	04.06-08.07.2026
Changelog	31.07.2026 - Final Report
Scope	Cartha: • https://github.com/hackenproof-public/cartha-vaults
Approved by	HackenProof team

AUDIT SUMMARY

46

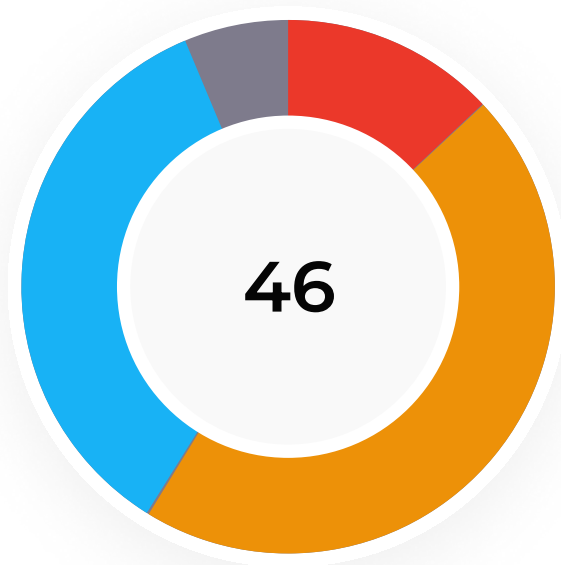
Total Findings

43

Resolved

3

Informative



• Critical	0
• High	6
• Medium	21
• Low	16
• None	3

FINDINGS LIST

• HIGH

	ZEROMARK-9 <u>Cartha vaults freeze (all deposits & withdrawals revert) whenever a child holds GM tokens -- GM valuation reads the transient OxM Oracle</u>	Resolved
	ZEROMARK-60 <u>gmValueInUsdc divides GM position value by 1e30 instead of 1e42 — 10¹² TVL inflation breaks all vault share accounting (depositor loss + permanent withdrawal freeze)</u>	Resolved
	ZEROMARK-67 <u>Re-bootstrap share inflation: a depositor re-triggers the first-deposit mint when supply > 0 but live TVL reads 0, minting cheap shares and diluting existing holders</u>	Resolved
	ZEROMARK-128 <u>Permanent freezing of funds: CarthaVault shares are transferable but have no position-less redemption</u>	Resolved
	ZEROMARK-129 <u>Theft of accrued yield via the asynchronous OxMarkets deploy and recall window</u>	Resolved



ZEROMARK-328

Underperformers can evade forced evictions

Resolved

• MEDIUM



ZEROMARK-11

First Depositor After Penalized Force Exit Can Steal Retained Vault Penalties

Resolved



ZEROMARK-50

removePool permanently strands the parent vault's GM-deployed value, causing parent LP insolvency

Resolved



ZEROMARK-70

Emergency pause does not halt privileged value-moving settlement

Resolved



ZEROMARK-103

Incorrect executionFee WNT receiver in Cartha's OxMarkets integration causes all non-zero-fee deploy/recall requests to revert, breaking pool liveness

Resolved



ZEROMARK-119

processQueuedWithdrawals Deletes Full Position After Shares Transferred Away — Permanently Breaks totalLockedAmount

Resolved



ZEROMARK-132

Cartha queued withdrawals can be expanded by a later top-up because top-up capital inherits the old lock start

Resolved



ZEROMARK-135

Expired child shares can escape underperformer force-exit penalty through parent vault

Resolved



ZEROMARK-137

CarthaVault temporary fund freeze: release/processQueuedWithdrawals pay only idle USDC vs full-TVL payout, freezing expired-lock LPs with no self-recovery when deployed in GM

Resolved



ZEROMARK-146

Unbounded Penalty in executeForceExit() — 100% Fund Wipeout via Missing Upper Bound Validation

Resolved



ZEROMARK-166

Parent Exits Depend On Off-Path Manual Child Recall While Share Pricing Assumes Deployed GM Is Liquid

Resolved



ZEROMARK-201

Cartha prices gm holdings with deposit pnl factor even though withdrawals realize withdrawal pnl factor

Resolved



ZEROMARK-210

Permissionless `release()` evades underperformer penalty depriving honest holders

Resolved



ZEROMARK-243

`extendLock()` interface says absolute new duration, implementation uses additive extension

Resolved

	ZEROMARK-257 <u>Permanent bricking of Parent Vault from direct non-Cartha Vault addition</u>	Resolved
	ZEROMARK-301 <u>Mismatch between `totalAssets` and `rebalanceToWeights` causes uneven fund distribution when a child vault is paused</u>	Resolved
	ZEROMARK-317 <u>Blacklisted USDC miners cannot be forcibly evicted from Vaults</u>	Resolved
	ZEROMARK-327 <u>withdrawToParent ceil-rounding can exceed depositFromParent minted shares</u>	Resolved
	ZEROMARK-710 <u>Missing `cancelDeposit()` wrapper can leave OxMarkets pending deposits unrecoverable</u>	Resolved
	ZEROMARK-1097 <u>Nonzero 0xM deploy and recall requests revert because Cartha sends execution-fee WNT to the vault instead of the OxMarkets request vault</u>	Resolved
	ZEROMARK-1122 <u>Unregistered referral codes give traders fee discounts and credit unclaimable affiliate rewards to `address(0)`</u>	Resolved
	ZEROMARK-1173 <u>`CarthaParentVault.withdraw()` Burns Full Shares While Silently Capping Payout on Shortfall</u>	Resolved

• LOW

	ZEROMARK-75 <u>Locked positions can be burned and deleted for a zero payout in `releaseFromParent` and `executeForceExit`</u>	Resolved
	ZEROMARK-80 <u>Cartha parent vault stores child allocation caps but never enforces them</u>	Resolved
	ZEROMARK-110 <u>Cartha recall hard-codes minLongTokenAmount to zero, leaving long-side OxMarkets withdrawal output unprotected</u>	Resolved
	ZEROMARK-145 <u>Silent Payout Shortfall in Parent Vault Withdrawal — Permanent Fund Loss via `_prepareSharePayout()` Always Returning sufficient = true</u>	Resolved
	ZEROMARK-240 <u>`lockTopUp` leaves `position.start` frozen letting matured-position top-ups bypass the lock window</u>	Resolved
	ZEROMARK-258 <u>Auto-Lock Renewal Can Bypass Updated maxLockDays Restriction</u>	Resolved

	ZEROMARK-344 <u>Rebalance Order Causes Withdrawn Assets to Remain Idle Until Next Rebalance</u>	Resolved
	ZEROMARK-581 <u>Withdrawal requests force users to fully exit positions on Parent or Child Vaults</u>	Resolved
	ZEROMARK-621 <u>`lastRebalanceTime` is not updated while calling `CarthaParentVault::removePool`</u>	Resolved
	ZEROMARK-694 <u>When `withdrawFromChildren` is called, balance is `pulled` from the `active-paused` vault but when calling `distributeToChildren` and `rebalanceToWeights` those `active-paused` vaults get nothing</u>	Resolved
	ZEROMARK-728 <u>Cartha redemptions value GM with deposit PnL factor, enabling inflated NAV payouts that shift losses to remaining holders</u>	Resolved
	ZEROMARK-771 <u>no setter for `\$.pools[vault].isActive` state on CarthaParentVault, as a result they get allocation even when admin want to deactivate them</u>	Resolved
	ZEROMARK-801 <u>`\$.pools[vault].maxAllocation` is not checked when doing assets allocation on `CarthaParentVault`</u>	Resolved
	ZEROMARK-873 <u>Parent vault withdrawal buffer is applied only to the availability check without a latter cap, causing valid withdrawals to revert during child pulls in some edge cases</u>	Resolved
	ZEROMARK-981 <u>Underperformer eviction merkle proof is replayable</u>	Resolved
	ZEROMARK-1121 <u>Missing pause guard in CarthaVault.processAutoLocks — keeper can re-lock matured positions during an emergency pause, freezing user funds</u>	Resolved

• NONE

	ZEROMARK-608 <u>Unlocked Parent shares cannot be transferred</u>	Informative
	ZEROMARK-898 <u>Parent Underperformer Force-Exit Incorrectly Requires Gross Liquidity Instead of Net Payout, Preventing Valid Penalized Exits</u>	Informative
	ZEROMARK-339 <u>USDC Is Recorded as the Long Leg for Mixed OxMarkets Markets, Making cvBTC/cvETH/cvTAO Deposits Unexecutable</u>	Informative

ABOUT PROJECT

OxMarkets is a decentralized perpetual protocol for trading crypto, forex, and real-world assets (RWA) on-chain.

DISCLAIMER

HackenProof Disclaimer

The application provided for assessment has been analyzed in accordance with generally accepted industry practices applicable at the time this report was prepared. The assessment focused on identifying cybersecurity vulnerabilities and security issues in the application's

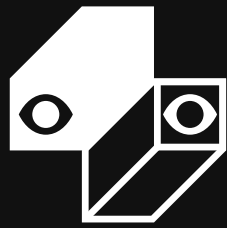
source code, deployment, configuration, and functionality, based solely on the materials, access, and scope made available for the engagement.

This report does not provide any representation or warranty that all vulnerabilities, weaknesses, or misconfigurations have been identified, nor does it guarantee the absolute security, reliability, or bug-free status of the application. The conclusions herein apply only to the specific version and scope reviewed and may no longer remain valid after any modification, update, or environmental change. This report should not be regarded as a definitive or exhaustive statement of the application's security posture.

Technical Disclaimer

Applications, whether decentralized applications (DApps) or other software systems, are deployed and operated within technical environments that may include blockchains, cloud services, operating systems, programming languages, frameworks, libraries, APIs, third-party services, and infrastructure components. Any of these elements may contain inherent weaknesses, undisclosed vulnerabilities, or configuration issues that can result in security incidents, operational failures, or unauthorized access.

The assessment reflects the condition of the application only at the time of testing and within the agreed scope, and the absence of findings in this report must not be interpreted as evidence that no vulnerabilities exist. Continuous security practices, including secure development, independent reviews, monitoring, patch management, and periodic reassessments, remain necessary to maintain an appropriate level of security.



HackenProof

Expert crowdsourced security provider

AUDIT CONTEST

Contact us:



[LinkedIn](#)



[X](#)



[Website](#)



[Mail](#)